

session-5

بخش اول: مرور ساختار شبکه و مدل‌های مرجع

۱. مدل لایه‌ای شبکه (Layered Format)

مدل لایه‌ای یک مفهوم انتزاعی است و در واقعیت لایه‌های ملموسی در شبکه وجود ندارد. هدف از این مفهوم، کشف بهتر کارکرد شبکه، تسهیل صحبت درباره آن و درک آسان‌تر عملکردها است.

۱.۱. مدل‌های مرجع

- **مدل مرجع OSI:** این مدل قدیمی‌تر و استاندارد اصلی شبکه بوده که ابتدا تعریف شده است.
- **مدل TCP/IP (مدل اینترنت):** این مدل پس از تحقیقات بیشتر و به مرور زمان ارائه شد و مدل ۵ لایه‌ای است که در اینترنت دنیا بر پایه آن بنا شده است.
- **تغییرات از OSI به TCP/IP:** در مدل TCP/IP، لایه‌های ۵ (Session) و ۶ (Presentation) با لایه ۷ (Application) تجمیع شده و زیرمجموعه لایه اپلیکیشن قرار گرفتند، زیرا فعالیت‌های آن‌ها مشابه لایه اپلیکیشن در نظر گرفته شد.
- **ساختار ۵ لایه‌ای TCP/IP:** لایه‌های مدل TCP/IP به ترتیب عبارتند از:
 1. Application (بالا ترین لایه)
 2. Transport (لایه مهم)
 3. Network (شاید مهم‌ترین لایه)
 4. Link
 5. Physical
- **توجه:** در برخی منابع، لایه‌های لینک و فیزیکی نیز با هم یکی شده و مدل ۴ لایه‌ای ارائه شده است، اما مدل اصلی، همان مدل ۵ لایه‌ای است.

۱.۲. تمرکز درسی آینده

- از فصل دوم به بعد، تمرکز کلاس بر اساس مدل TCP/IP خواهد بود و هر فصل به یک لایه اختصاص داده می‌شود.
- **لایه فیزیکی:** این لایه فاکتور گرفته می‌شود (حذف می‌شود) زیرا بیشتر مربوط به قسمت سخت‌افزاری کار بوده و در سرفصل کلاس جایگاه کمتری دارد.
 - **ترتیب فصول:** ابتدا از لایه Application (پنجمین لایه) شروع می‌شود، زیرا معروف‌ترین لایه و بیشتر در ارتباط با کاربر است. سپس به ترتیب لایه‌های Network، Transport، و Link بررسی خواهند شد.

۲. کپسوله‌سازی (Encapsulation)

- کپسوله‌سازی مفهومی است که بر اساس همین لایه‌ها تعریف می‌شود.
- **فرآیند:** به ترتیب در هر لایه‌ای که اتفاقی می‌افتد، آن لایه هدر خود را می‌گیرد و به لایه بعد می‌رود.
 - **مقصد:** در مقصد، فرآیند دقیقاً برعکس کپسوله‌سازی است.

بخش دوم: امنیت شبکه (Network Security)

۱. اهمیت امنیت شبکه

امنیت یک مسئله بسیار مهم است که در تمام جوانب جامعه (درس، زندگی، کار، سیاست، اقتصاد) با توجه به بستر مربوطه، تعریف می‌شود.

- **امنیت شبکه:** این موضوع یک فاکتور حیاتی و بسیار مهم در شبکه است.
- **تخصص:** امنیت شبکه به قدری مهم و گسترده است که تبدیل به یک فیلد کاری و تحصیلی جداگانه (رشته/درس Network Security) شده است و دنیایی از دانش و اطلاعات را شامل می‌شود.
- **حذف بخش تاریخچه:** قسمت ۱.۷ (تاریخچه) از فصل یک، اطلاعات عمومی است و حذف شده است و علاقه‌مندان می‌توانند به کتاب مراجعه کنند.
- **منابع تکمیلی:** در کتاب منبع، فصل ۸ یا ۱۰ به طور جداگانه راجع به سکیوریتی صحبت کرده است که برای علاقه‌مندان قابل مطالعه است.

۲. مسائل محوری امنیت شبکه

امنیت شبکه بر اساس سه دیدگاه و سه سوال اصلی تعریف می‌شود:

۱. **حمله‌ها:** چطور یک فرد می‌تواند به شبکه حمله کند؟ (حمله‌ها چه هستند؟).
۲. **دفاع:** چطور می‌توانیم در برابر حمله‌ها دفاع کنیم؟ (روش‌های دفاعی چیست؟).
۳. **طراحی:** چطور طراحی شبکه‌ای داشته باشیم که کلاً نسبت به حمله‌ها ایمن باشد (ایمیون باشد؟).

۳. ناامنی فضای اینترنت

اینترنت جای امنی نیست و نمی‌تواند شبکه امنی در دنیا باشد.

- **دلیل:** دلیل ناامنی این است که کاربران مختلفی با سطوح کاری، زندگی، سنی و مقاصد متفاوت (استفاده درست یا غلط، قصد و غرض مخرب) به شبکه وصل می‌شوند و آگاهی کاملی نسبت به کاربران و فضای شبکه وجود ندارد.
- **تمثیل مرغ و تخم‌مرغ:** مسئله امنیت شبیه قضیه مرغ و تخم‌مرغ است؛ تا زمانی که حمله وجود دارد، نرم‌افزار دفاعی تولید می‌شود، و تا زمانی که دفاع وجود دارد، مهاجمان حمله بزرگتر و عجیب‌تری انجام می‌دهند.

بخش سوم: بدافزارها (Malware)

تعریف: بدافزار (Malware) مخفف Malicious Software به معنی نرم‌افزار مخرب است. تاریخچه بدافزارها به ۴۰ یا ۵۰ سال پیش باز می‌گردد و چیز جدیدی نیست.

۱. انواع بدافزارهای رایج

سه بدافزار بسیار معروف در دنیا عبارتند از: ویروس، کرم و تروجان.

۱.۱. ویروس (Virus)

- **تعریف:** یک نمونه از بدافزارها و نرم‌افزار مخرب است.
- **میزبان:** ویروس به یک سند، فایل یا هر چیز دیگری در کامپیوتر می‌چسبد (متصل می‌شود) و از آن میزبان استفاده می‌کند تا اجرا شود.
- **اجرا:** تا زمانی که کاربر فایل میزبان را باز نکرده و از آن استفاده نکند، ویروس **غیرفعال** است. به محض اجرای فایل، ویروس فعال شده و دستورات خود (مثل پاک کردن فایل‌ها، پنهان کردن، خاموش کردن سیستم یا انتشار عکس) را انجام می‌دهد.
- **نکته مهم:** همیشه باید از کلیک کردن یا اجرای فایل‌های مشکوک خودداری شود، مگر اینکه از منبع آن مطمئن باشید.

۱.۲. کرم (Worm)

- **انتشار:** کرم نیز منتشر می‌شود و از کامپیوتری به کامپیوتر دیگر پخش می‌شود.
- **سرعت:** سرعت پخش کرم در شبکه بیشتر از ویروس است.
- **نیاز به میزبان:** برخلاف ویروس، کرم نیازی به برنامه میزبان ندارد.
- **عملکرد:** کرم یک فایل مخرب است که از طریق اتصال به شبکه آلوده یا دانلود فایل وارد سیستم شده و شروع به انتشار و انجام کار مخرب می‌کند.
- **ظاهر قانونی:** معمولاً کرم دارای وجهت قانونی است، مثلاً به شکل یک فایل PDF که کاربر همیشه استفاده می‌کرده است، وارد سیستم می‌شود و آن را آلوده می‌کند.

۱.۳. تروجان (Trojan Horse)

- **ایده:** ایده تروجان از داستان اسب چوبی تروی در رم باستان گرفته شده است.
- **عملکرد:** تروجان وارد سیستم شده و خود را به عنوان یک **برنامه مفید** پنهان می‌کند. اما پس از دانلود، دسترسی پیدا می‌کند به داده‌های حساس، آن‌ها را حذف یا پاک می‌کند.
- **تکثیر:** تروجان مانند ویروس تکثیر نمی‌شود، اما با ایجاد خرابی و مشکل برای سیستم، مضر است.

۲. بدافزارهای دیگر

علاوه بر سه مورد بالا، نرم‌افزارهای مخرب دیگری نیز وجود دارند:

نوع بدافزار	نام انگلیسی	عملکرد و مثال
جاسوس افزار	Spyware	مخفیانه اجرا می‌شود و گزارش تهیه می‌کند (جاسوسی) تا اطلاعات حساس را در اختیار هکر قرار دهد. مثال معروف آن کیلاگر (Keylogger) است که کلیدهای فشار داده شده روی کیبورد (مانند پسوردها، یوزرنیم‌ها، ایمیل‌ها و آدرس‌های وب) را ضبط کرده و اطلاعات را برای هکر می‌فرستد.
تبلیغ افزار	Adware	نرم‌افزار مخرب تبلیغاتی که برای جمع‌آوری داده استفاده می‌شود و تبلیغات ارائه می‌دهد. این کار می‌تواند سرعت سیستم را کم کند یا ناگهان تصاویری را روی مانیتور نمایش دهد.
باچ افزار	Ransomware	نرم‌افزاری که برای درخواست باج استفاده می‌شود.
بات‌نت‌ها	Botnets	یکی از رایج‌ترین بدافزارهای شبکه هستند. از دو کلمه بات (Bot به معنی زامبی یا روبات) و نت (Network) تشکیل شده‌اند. اینها سیستم‌های آلوده‌ای هستند که بدون اطلاع صاحبشان از طریق شبکه آلوده می‌شوند و یک مهاجم از طریق کد بات، دستورات مخرب را اجرا می‌کند.
بدافزار بدون فایل	Fileless Malware	بدافزاری که بدون نیاز به فایل خاصی اجرا می‌شود.
Scareware	اسکیر	نوعی بدافزار که با ایجاد ترس، کاربر را وادار به کاری می‌کند.

کارکردهای بات‌نت‌ها: بات‌نت‌ها می‌توانند حملات مختلفی را اجرا کنند، از جمله: ارسال ایمیل اسپم، استفاده از اسپایورها/کیلاگرها، انجام حملات منع سرویس (DoS)، کرک کردن پسوردها و تقلب در بازی‌ها.

بخش چهارم: حملات شبکه (Network Attacks)

سه نوع حمله رایج و قدیمی که هنوز هم در دنیا مورد استفاده قرار می‌گیرند:

۱. حمله انکار سرویس (DoS/DDoS)

حمله‌ای است که سرور یا خدمات شبکه را تحت تأثیر قرار می‌دهد.

نوع حمله	نام کامل	عملکرد
DoS	Denial of Service (انکار سرویس)	یک سیستم مخرب وارد شبکه شده و با ارسال ترافیک یا داده زیاد، سرور را دچار سردرگمی می‌کند. این باعث می‌شود سرور داون شده و سایر سیستم‌ها نتوانند از آن استفاده کنند.
DDoS	Distributed Denial of Service (انکار سرویس توزیع شده)	در این حمله تعداد کامپیوترهایی که حمله می‌کنند بیشتر است. چند کامپیوتر با هدف و به صورت جمعی، شروع به ارسال درخواست‌های غیرمنطقی یا ترافیک مخرب می‌کنند، پهنای باند را می‌گیرند و سرور نمی‌تواند پاسخگویی کند و در نتیجه از کار می‌افتد (داون می‌شود).
نکته		این حمله شبیه به هجوم کاربران در زمان انتخاب واحد یا کنکور به یک سامانه است، با این تفاوت که در حمله DoS/DDoS، ارتباطات با هدف مخرب انجام می‌شود.

۲. شنود بسته‌ها (Packet Sniffing)

- تعریف:** اسنیفینگ یک نرم‌افزار یا سخت‌افزاری است که روی ترافیک شبکه نظارت می‌کند و جریان داده‌ها را بین مبدا و مقصد بررسی می‌کند.
- عملکرد:** اسنیفرها (شنودکننده‌ها) اطلاعات را شنود می‌کنند و داده‌های مورد نیاز خود را (مثلاً اطلاعات مهم) کپی می‌کنند. در حین شنود، ارتباط اصلی بین سرور برقرار است و اتفاق خاصی نمی‌افتد.
- انواع شنود:**
 - آن فیلتر (Unfiltered):** بدون فیلتر، تمام داده‌ها را بر اساس نیاز داندلود و روی حافظه ذخیره می‌کند.
 - فیلتر شده (Filtered):** فقط بسته‌های فیلتر شده یا داده‌هایی که مورد نیاز هکر هستند (مثلاً فقط پسوندها) را جمع‌آوری می‌کند.
- مثال:** شنود ایمیل‌ها، رمزها، پیکربندی روتر، چت‌های آنلاین و ترافیک DNS.
- ابزارها:** ابزارهای زیادی برای تجزیه و تحلیل ترافیک وجود دارد. یکی از معروف‌ترین ابزارهای اسنیفینگ **Wireshark** است. ابزارهای دیگر شامل Ethercap و NetWitness هستند.

۳. جعل آی‌پی (IP Spoofing)

- تعریف:** به معنی جعل آی‌پی است. در این حمله، داده‌ای که به سمت سرور ارسال می‌شود، از طرف یک آدرس مبدأ تقلبی ارسال می‌شود.
- عملکرد:** آدرس مبدأ تغییر پیدا می‌کند و هویت ارسال‌کننده پنهان می‌شود (جعل هویت).
- کاربردها:** در کارهای بانکی رایج است. کاربر فکر می‌کند به درگاه اصلی بانک وصل شده، اما در واقع از یک درگاه تقلبی استفاده می‌کند که آی‌پی جعلی دارد.
- نکته:** تغییر کوچک در آدرس سایت می‌تواند سیستم را فریب دهد.
- ارتباط با سایر حملات:** حملاتی مانند دیداس می‌توانند از تکنیک آی‌پی اسپوفینگ (آدرس‌های جعلی) استفاده کنند تا داده‌ها را تحت تأثیر قرار دهند.

۴. حمله ضبط و پخش مجدد (Record and Replay Attack)

- تعریف:** این حمله در واقع همان شنود اطلاعات است (اسنیفینگ)، اما به طور خاص اطلاعات حساس مانند پسوندها را ضبط (ریکورد) می‌کند و در زمانی که نیاز باشد، از آن پسوندها استفاده می‌کند.

۵. روش‌های پیشگیرانه عمومی

برخی اقدامات روتین و ساده برای جلوگیری از حملات عبارتند از:

- مطمئن شدن از ایمن بودن شبکه و وای‌فای مورد استفاده.
- مطمئن شدن از آدرس وبسایت‌های بازی شده (به خصوص درگاه‌های بانکی).

- نصب آنتی‌ویروس روی سیستم.
 - توجه به ایمیل‌ها یا لینک‌های عجیب و غریبی که ارسال می‌شوند.
-

تشبیه برای فهم بهتر: مسئله امنیت در شبکه (Malware و حملات) مانند یک نبرد بی‌پایان بین **کلیدسازان** و **سارقان** در یک شهر بزرگ است. کلیدسازان (شرکت‌های امنیتی) همواره در حال ساختن قفل‌ها و دژهای جدیدتر (نرم‌افزارهای دفاعی) هستند، اما سارقان (هکرها) نیز همیشه ابزارهای جدیدتر (Malware) یا روش‌های فریبنده‌تر (Trojan یا IP Spoofing) برای عبور از آن قفل‌ها اختراع می‌کنند. این فرآیند دوام دارد و هیچ‌کس نمی‌تواند ادعا کند که قفل نهایی و نشکن را ساخته است، چون سارقان نیز دائماً روش‌های خود را به‌روزرسانی می‌کنند.